TRUST-FIRST CARENOTE

Nightingale 72 Hour Build - Technical Brief | Peiheng Li

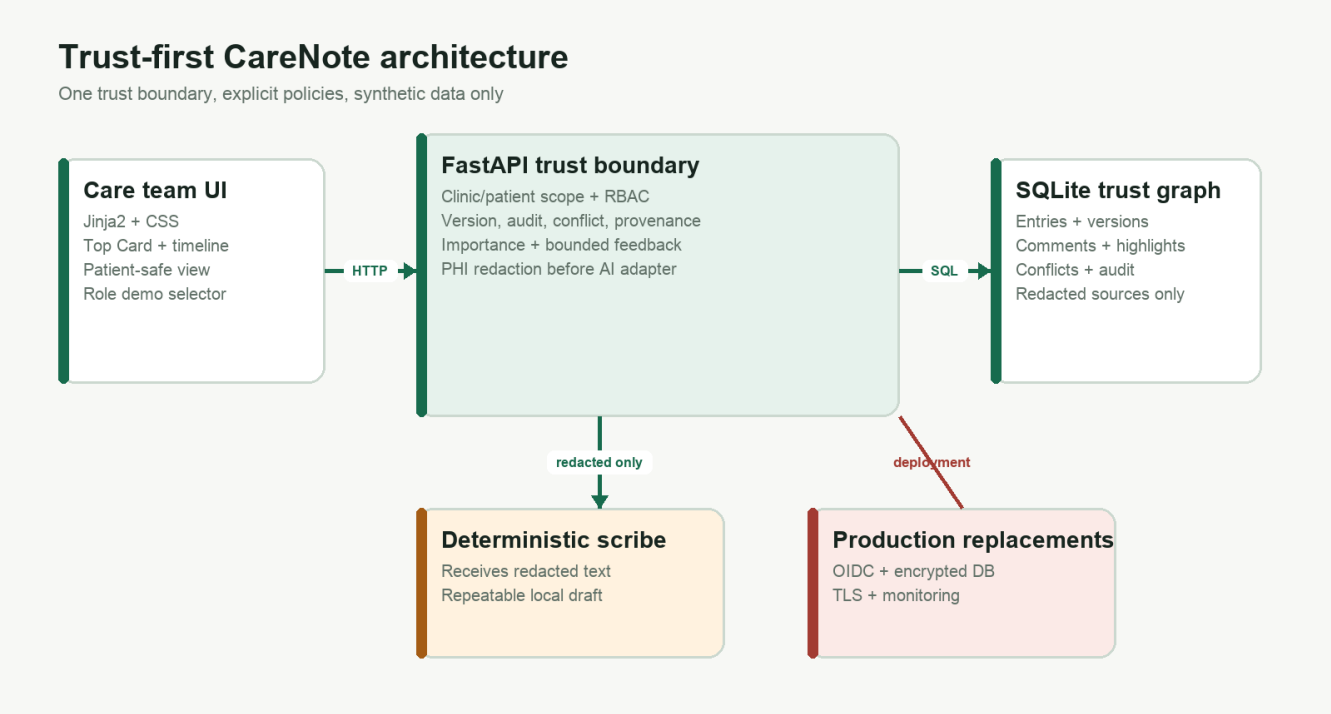
A 10-second clinical brief is only useful when every claim can be traced, challenged, and corrected without weakening role boundaries.

1. Product decision

EHR tables hold snapshots, but care teams reason from the story between them. CareNote treats the longitudinal timeline as the source of truth and the Top Card as a small derived view - never a summary that can silently drift.

- Glanceability: five or fewer ranked items show risk, open work, context, and a short reason.
- Trust: every highlight resolves to an exact entry and character span; conflicts stay visible until reviewed.
- Safe collaboration: server-side patient/staff/clinician/admin rules prevent cross-role overwrite and patient exposure to internal comments or raw AI notes.

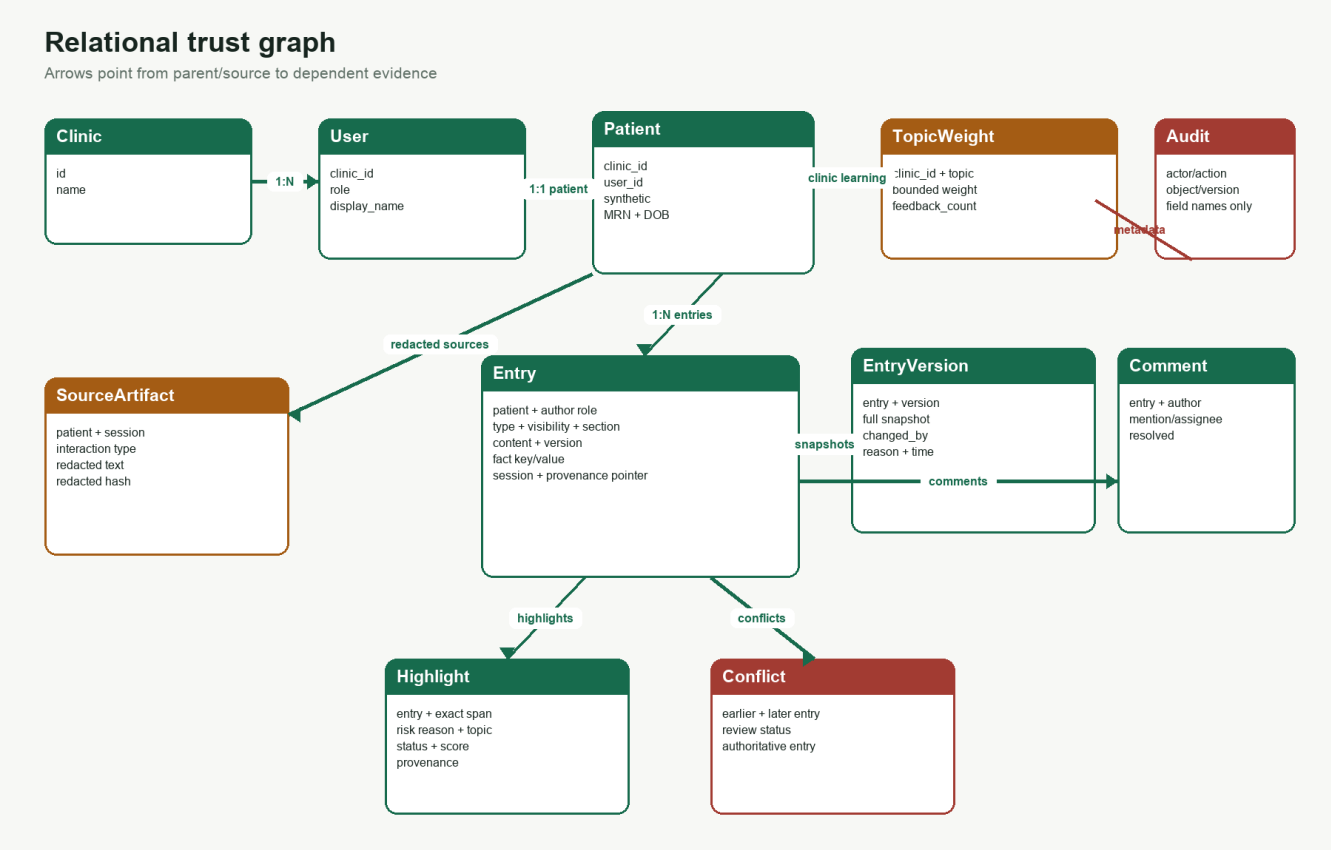
2. Architecture



The browser does not decide authorization. Each protected request checks actor role, clinic scope, patient ownership, entry visibility, and role-owned writes. X-User-ID selects a seeded demo identity only; production replaces it with verified OIDC while retaining the policies.

DATA, VERSIONS, AND PROVENANCE

A relational trust graph keeps content, evidence, collaboration, and learning connected.



3. Trust flows

AI scribe	Redact known/labelled names, IC/FIN, phone, and email; persist only the redacted source; pass only redacted text to the deterministic adapter; save a distinct system entry with session provenance.
Edit + revert	Require expected_version. A match creates a full immutable snapshot and metadata-only audit event. A stale same-entry write returns 409. Revert restores a snapshot as a new version.
Highlight	The server derives text from validated character bounds. The pointer resolver rechecks scope, visibility, entry identity, and span bounds before returning the exact substring.
Conflict	Different structured values from patient/system and clinician sources create a review object. Nothing is silently overwritten; clinician/admin explicitly selects the authoritative entry.

4. Explainable importance

Score = risk + recency + unresolved + review status + bounded topic weight. Pin/accept/reject change the visible status and update clinic topic feedback by +8/+4/-6; a clinician comment on an AI topic adds +1. Topic learning is visible and bounded from -20 to +30, so adaptation cannot become an opaque or runaway model.

SECURITY, EVIDENCE, AND TRADE-OFFS

The prototype makes narrow claims and shows the evidence behind each one.

5. Security and privacy

- Clinic-scoped RBAC is enforced in FastAPI; out-of-scope records return 404 to avoid confirming existence.
- Patients cannot retrieve internal comments, clinical Top Card data, or raw AI-scribed entries.
- Audit events contain actor, action, object, versions, changed field names, and time - never note bodies.
- All repository data is fictional and labelled synthetic. The raw scribe transcript is never stored.

6. Performance evidence

P50	P95	P99	Max	Target
1.83 ms	**2.09 ms**	**2.28 ms**	**12.21 ms**	**<= 300 ms**

Darwin arm64, Python 3.9.6; 20 warm-ups and 300 in-process authenticated Top Card requests. Includes routing, RBAC, SQLite, ranking, and serialization. Excludes TLS, network, browser rendering, concurrent production load, and managed-database latency; it is an approximation, not a production SLO.

7. Automated evidence

RBAC scope	Cross-role writes, patient-safe output, clinic isolation
Revision history	Version increment, diff, revert, metadata-only audit
Provenance	Every Top Card highlight resolves to exact source text
Concurrent edits	Independent sections succeed; stale same-entry write is 409
Self-learning	Pin feedback raises subsequent same-topic suggestion by 8
Full suite	22 passing tests; warm P95 gate <= 300 ms

8. Trade-offs and next steps

I chose a working trust loop over voice capture, real EHR integration, CRDT editing, or an opaque ML model. SQLite and header-selected demo identity are prototype choices, not production security claims. Next: verified OIDC, encrypted managed PostgreSQL with defense-in-depth row policies, schema migrations, retention/backups, security monitoring, clinical workflow testing, then structured extraction and voice capture behind the same redaction and provenance boundary.

Scope statement Synthetic data only. No external AI model, EHR, audio, or real patient information is used.